

# RECONPRO

## FORENSIC CAPABILITY AUDIT

Complete read-only verification of all claimed capabilities against actual source code evidence.

Audit Date: August 13, 2026

Methodology: Source-code forensic inspection, static analysis, test execution, build verification

Repository: /home/z/my-project (Next.js 16 + TypeScript + Tailwind + Prisma)

### CLASSIFICATION: READ-ONLY FORENSIC VERIFICATION

Zero source files modified. Zero tests modified. Zero dependencies changed.

# 1. Repository Map

The ReconPro repository is a Next.js 16 application built with TypeScript, Tailwind CSS 4, Framer Motion, Prisma ORM (SQLite), and shadcn/ui components. The codebase is organized into a standard Next.js App Router structure with a comprehensive API layer, 70+ React components, and a rich set of security/reconnaissance modules. The repository also contains a separate Python CLI tool (vibsec-cli) and supporting scripts, but the primary application is the Next.js web platform. The total source file count in the src/ directory is 225 files, comprising API routes, UI components, hooks, libraries, tests, and configuration files.

The project uses Bun as its JavaScript runtime and package manager, with a comprehensive dependency list including React 19, Prisma 6.11, TweetNaCl for cryptographic operations, and @noble/hashes for SHA-256. The build system produces a standalone server with static asset copying. TypeScript strict mode is enabled with ignoreBuildErrors set to false, meaning all type errors block production builds. The linting configuration uses ESLint 9 with the Next.js preset, and all 0 errors/0 warnings are maintained.

## 1.1 Source File Inventory

| Metric                                | Count |
|---------------------------------------|-------|
| Total src/ files                      | 225   |
| API route files (route.ts)            | 46    |
| ReconPro UI components                | 70    |
| shadcn/ui components                  | 40    |
| Custom hooks                          | 6     |
| Library modules (src/lib/)            | 14    |
| Recon engine modules (src/lib/recon/) | 7     |
| Test files (src/__tests__)            | 22    |
| Prisma schema models                  | 17    |
| Data files                            | 1     |
| SEO components                        | 1     |
| Background components                 | 1     |

## 1.2 Technology Stack

| Layer        | Technology           | Version |
|--------------|----------------------|---------|
| Framework    | Next.js (App Router) | 16.1.1  |
| Language     | TypeScript           | 5.x     |
| UI Framework | React                | 19.0    |
| Styling      | Tailwind CSS         | 4.x     |
| Animation    | Framer Motion        | 12.23.2 |
| ORM          | Prisma Client        | 6.11.1  |

| Layer             | Technology                | Version       |
|-------------------|---------------------------|---------------|
| Database          | SQLite                    | (file-based)  |
| Crypto            | TweetNaCl + @noble/hashes | 1.0.3 / 2.2.0 |
| Component Library | shadcn/ui + Radix         | latest        |
| Charts            | Recharts                  | 2.15.4        |
| Testing           | Vitest + Testing Library  | 4.1.10        |
| Runtime           | Bun                       | (latest)      |
| Font              | Noto Sans SC / Tinos      | system        |

## 1.3 API Route Map (46 routes)

| Route                    | Methods               | Purpose                       | Verdict |
|--------------------------|-----------------------|-------------------------------|---------|
| /api/scan                | POST                  | Full reconnaissance scan      | REAL    |
| /api/scan/stream         | GET                   | SSE scan progress (fake)      | UI-ONLY |
| /api/vuln-scan           | POST                  | Vulnerability scanning        | REAL    |
| /api/bot-hunter          | POST                  | Botnet/IP threat analysis     | REAL    |
| /api/oblivion            | GET/POST              | AI red teaming                | UI-ONLY |
| /api/model-redteam       | POST                  | AI model security testing     | MOCK    |
| /api/hall-of-fame        | GET/POST              | Security grade leaderboard    | REAL    |
| /api/sovereign           | GET/POST              | Founder crypto authority      | MOCK    |
| /api/sandbox             | GET/POST              | Confused Deputy sandbox       | REAL*   |
| /api/teams               | GET/POST/PATCH/DELETE | Team CRUD                     | REAL    |
| /api/members             | GET/POST/PATCH/DELETE | Member CRUD                   | REAL    |
| /api/scans               | GET                   | Scan history                  | REAL    |
| /api/nhi                 | GET/POST              | NHI identity management       | MOCK    |
| /api/nhi/assess          | POST                  | NHI risk assessment           | REAL    |
| /api/nhi/audit           | GET                   | NHI audit log                 | REAL    |
| /api/nhi/revoke          | POST                  | NHI kill switch               | REAL    |
| /api/nhi/rollback        | POST                  | NHI rollback                  | REAL    |
| /api/nhi/seed            | POST                  | NHI sample seeding            | MOCK    |
| /api/v1/auth/validate    | POST                  | API key validation            | REAL    |
| /api/genesis             | POST                  | Genesis stamp issuance        | REAL    |
| /api/genesis/verify/[id] | GET                   | Genesis stamp verification    | REAL    |
| /api/genesis/revoke      | POST                  | Genesis stamp revocation      | REAL    |
| /api/genesis/embed/[id]  | GET                   | Badge embed HTML              | REAL    |
| /api/broadcast           | GET/POST              | Security broadcast management | REAL    |
| /api/broadcast/active    | GET                   | Active broadcasts             | REAL    |

| Route                      | Methods | Purpose                    | Verdict |
|----------------------------|---------|----------------------------|---------|
| /api/broadcast/verify/[id] | GET     | Broadcast verification     | REAL    |
| /api/fear-index            | GET     | CISO Fear Index            | PARTIAL |
| /api/fear-index/history    | GET     | Fear Index history         | PARTIAL |
| /api/fear-index/feed       | GET     | Fear Index RSS feed        | PARTIAL |
| /api/doom-clock            | GET     | Quantum Doom Clock         | PARTIAL |
| /api/pqc-vault             | POST    | PQC readiness assessment   | PARTIAL |
| /api/cni-sentinel          | POST    | CNI threat analysis        | PARTIAL |
| /api/implosion             | POST    | Executive risk simulation  | REAL    |
| /api/compliance            | POST    | Compliance framework audit | REAL    |
| /api/dashboard             | GET     | Dashboard aggregate data   | REAL    |
| /api/executive             | GET     | Executive summary data     | REAL    |
| /api/threats               | GET     | Threat alerts              | REAL    |
| /api/exposed-assets        | GET     | Exposed asset map          | REAL    |
| /api/wall-of-shame         | GET     | Wall of Shame entries      | REAL    |
| /api/ai-advisor            | GET     | AI security advisor        | PARTIAL |
| /api/ai-leaderboard        | GET     | AI model leaderboard       | PARTIAL |
| /api/monitoring            | GET     | Monitoring data            | REAL    |
| /api/integrations          | GET     | Integration list           | REAL    |
| /api/audit                 | GET     | Audit log entries          | REAL    |
| /api/health                | GET     | Health check               | REAL    |
| /api/cognitive-dread       | GET     | Cognitive Dread Index      | PARTIAL |

\* Sandbox is real by design -- it simulates an AI agent for training purposes.

## 2. Actual Baseline (Measured)

All baseline metrics were measured directly from the repository during this forensic audit. Previous reports, claims, and conversation summaries were explicitly disregarded as untrusted. The following numbers represent the verified current state of the codebase as of August 13, 2026.

| Metric                               | Verified Value                                            | Method                                       |
|--------------------------------------|-----------------------------------------------------------|----------------------------------------------|
| TypeScript Errors                    | 0                                                         | <code>npm tsc --noEmit</code>                |
| Lint Errors/Warnings                 | 0                                                         | <code>npm eslint .</code>                    |
| Build Status                         | PASS                                                      | <code>npm next build</code>                  |
| Total Test Files                     | 22                                                        | <code>find src/ __tests__</code>             |
| Total Tests                          | 562                                                       | <code>npm vitest run</code>                  |
| Tests Passed                         | 562                                                       | vitest output                                |
| Tests Failed                         | 0                                                         | vitest output                                |
| Test Duration                        | 20.27s                                                    | vitest output                                |
| API Routes                           | 46                                                        | <code>find src/app/api -name route.ts</code> |
| ReconPro Components                  | 70                                                        | <code>find src/components/reconpro</code>    |
| shadcn/ui Components                 | 40                                                        | <code>find src/components/ui</code>          |
| Prisma Models                        | 17                                                        | <code>prisma/schema.prisma</code>            |
| Source Files (src/)                  | 225                                                       | <code>find src -type f</code>                |
| Security Middleware                  | ACTIVE                                                    | <code>src/middleware.ts</code>               |
| CSP Nonce                            | PER-REQUEST                                               | <code>crypto.randomUUID()</code>             |
| HSTS                                 | <code>max-age=31536000; includeSubDomains; preload</code> | <code>middleware.ts</code>                   |
| <code>child_process</code> Usage     | 0 instances                                               | <code>grep child_process</code>              |
| <code>dangerouslySetInnerHTML</code> | 0 instances                                               | <code>grep dangerouslySetInnerHTML</code>    |
| <code>eval()</code> Usage            | 0 instances                                               | <code>grep eval(</code>                      |

# 3. Capability Inventory

## 3.1 Reconnaissance Capabilities (Domain-Level)

ReconPro implements genuine domain-level reconnaissance through native Node.js modules. The scan engine in `src/app/api/scan/route.ts` (1,245 lines) performs real DNS resolution via `dns.promises` with custom resolvers (8.8.8.8, 1.1.1.1, 9.9.9.9), real TLS handshakes via the `tls` module for SSL certificate analysis, real HTTP requests via `safeFetch` for security header and technology detection, real TCP port probing via the `net` module, and real Certificate Transparency log queries to `crt.sh`. Additionally, the separate `lib/recon/` modules provide reusable, well-tested recon primitives with proper SSRF protection.

| Capability             | File(s)                                                      | Implementation                                                  | Tests                    | Status      |
|------------------------|--------------------------------------------------------------|-----------------------------------------------------------------|--------------------------|-------------|
| Domain Validation      | <code>api-security.ts</code> ,<br><code>ssrf-guard.ts</code> | Regex + DNS resolution check                                    | Yes (5 files)            | REAL        |
| Domain Normalization   | <code>api-security.ts</code>                                 | <code>sanitizeDomain()</code> : strip protocol, lowercase, trim | Yes                      | REAL        |
| DNS Lookup (A/AAAA)    | <code>dns-recon.ts</code> ,<br><code>scan/route.ts</code>    | <code>dns.promises.resolve4/6</code> with custom resolvers      | Yes (mocked)             | REAL        |
| DNS Record Enumeration | <code>dns-recon.ts</code>                                    | A, AAAA, MX, NS, TXT, CNAME, SOA in parallel                    | Yes (mocked)             | REAL        |
| IP Resolution (IPv4)   | <code>dns-recon.ts</code>                                    | A record resolution                                             | Yes                      | REAL        |
| IP Resolution (IPv6)   | <code>dns-recon.ts</code>                                    | AAAA record resolution                                          | Yes (ipv6-ssrf-hardened) | REAL        |
| Hostname Discovery     | <code>dns-recon.ts</code>                                    | NS, MX, CNAME records                                           | Yes                      | REAL        |
| SPF/DMARC Analysis     | <code>dns-recon.ts</code>                                    | TXT record parsing + classification                             | Yes                      | REAL        |
| Reverse DNS            | <code>bot-hunter/route.ts</code>                             | <code>dns.promises.resolve4</code> reverse                      | No                       | REAL        |
| WHOIS Lookup           | <code>bot-hunter/route.ts</code>                             | <code>run()</code> command interpreter (always returns empty)   | No                       | NOT WORKING |
| CT Log Discovery       | <code>ct-logs.ts</code>                                      | <code>crt.sh</code> API with response streaming + 5MB cap       | No                       | REAL        |
| TLS/SSL Inspection     | <code>ssl-recon.ts</code>                                    | Real TLS handshake + cert analysis                              | Yes (mocked)             | REAL        |
| Certificate Metadata   | <code>ssl-recon.ts</code>                                    | Subject, issuer, dates, SAN, serial, cipher                     | Yes                      | REAL        |
| HTTP Header Analysis   | <code>http-recon.ts</code>                                   | 8 security headers checked (HSTS, CSP, X-Frame, etc.)           | Yes                      | REAL        |
| Technology Detection   | <code>http-recon.ts</code>                                   | 35+ fingerprints (CDN, server, framework, CMS, analytics)       | No                       | REAL        |
| Port Probing           | <code>port-check.ts</code>                                   | TCP connect to 27 unique ports with timeout                     | Yes (mocked)             | REAL        |
| Subdomain Enumeration  | <code>ct-logs.ts</code> + <code>scan/route.ts</code>         | 60-90 subdomains from CT logs + batched DNS                     | No                       | REAL        |

| Capability              | File(s)                  | Implementation                                     | Tests | Status |
|-------------------------|--------------------------|----------------------------------------------------|-------|--------|
| Wayback Machine         | scan/route.ts            | Wayback CDX API for URL history                    | No    | REAL   |
| JS File Analysis        | scan/route.ts            | Download + regex for API endpoints, secrets, paths | No    | REAL   |
| WAF Detection           | scan/route.ts            | Path traversal probe + rate limit test             | No    | REAL   |
| Email Harvesting        | scan/route.ts            | Regex extraction + MX infrastructure analysis      | No    | REAL   |
| Network/Service Probing | port-check.ts, vuln-scan | TCP banner grab on 22+ ports                       | No    | REAL   |

## 3.2 Attack-Surface Discovery

Attack-surface discovery is primarily driven by the CT log subdomain enumeration, port scanning, and the deep fingerprinting engine. These produce real findings from live network operations. The attack-surface visualization and mapping features are UI-only representations of scan data -- there is no dedicated attack-surface graph engine or asset relationship database in the backend. Assets are stored as flat scan targets with no explicit inter-asset relationship model in the Prisma schema.

| Capability                   | Implementation                                                      | Status    |
|------------------------------|---------------------------------------------------------------------|-----------|
| Subdomain Discovery          | CT logs (crt.sh) + batched DNS resolution of 60-90 patterns         | REAL      |
| Host Discovery               | DNS A/AAAA resolution + reverse DNS                                 | REAL      |
| DNS Intelligence             | Full record enumeration (7 types) + SPF/DMARC/SECURITY.TXT analysis | REAL      |
| IP Intelligence              | DNS resolution + private IP detection + geolocation (ip-api.com)    | REAL      |
| Service Discovery            | TCP port scanning of 27 critical ports                              | REAL      |
| Port Checking                | Individual TCP connect with per-port timeout                        | REAL      |
| TLS Discovery                | Full TLS handshake + cert chain analysis                            | REAL      |
| HTTP Discovery               | HTTP/HTTPS fetch with header/tech analysis                          | REAL      |
| Certificate Intelligence     | CT log mining + cert metadata extraction                            | REAL      |
| Attack-Surface Mapping       | UI visualization of scan data (no graph backend)                    | UI-ONLY   |
| Asset Aggregation            | ScanTarget model (flat, no relationships)                           | PARTIAL   |
| Asset Relationships          | Not implemented in schema                                           | NOT FOUND |
| Attack-Surface Visualization | react component with hardcoded demo data                            | UI-ONLY   |

## 4. Specialized Module Audit

---

### 4.1 Vulnerability Scanner (vuln-scan)

The vulnerability scanner (`src/app/api/vuln-scan/route.ts`, 903 lines) is a REAL implementation. It performs actual network-level vulnerability checks through a command-interpreter pattern that reconstructs `curl/dig/openssl/nc` behavior using native Node.js APIs. The scanner implements: TCP banner grabbing on 22 ports with CVE matching against a 35+ entry CVE database; HTTP vulnerability checks including CORS misconfiguration, open redirect, path traversal, SSRF, XSS, clickjacking, cookie security, CSRF, and mixed content analysis; SSL vulnerability checks including protocol version analysis, weak cipher detection, Heartbleed detection, certificate expiry analysis, and perfect forward secrecy verification; and DNS vulnerability checks including AXFR zone transfer attempts, subdomain takeover detection (Heroku, S3, GitHub Pages), cache snooping, and DNS rebinding analysis. The command interpreter pattern avoids `child_process.exec` entirely, using `dns.promises`, `tls.connect`, and `safeFetch` instead. However, the AXFR check is effectively a no-op (returns empty), and the whois lookup always returns empty as well.

### 4.2 Bot Hunter

The Bot Hunter (`src/app/api/bot-hunter/route.ts`, 598 lines) is a REAL implementation with minor caveats. It performs: IP reputation scanning via `ip-api.com` (geolocation, ISP, proxy detection) and `ipinfo.io` (ASN lookup); reverse DNS resolution; Tor exit node checking; DNS blacklist lookups across 4 providers (SORBS, SpamCop, Spamhaus, CBL); TCP banner grabbing on 30 known C2 ports; malware family signature matching against 18 families; DNS-based bot detection analyzing TXT records for base64 C2 beacons, CNAME chain analysis, and DNS tunneling patterns; typosquatting detection using Levenshtein distance; and a threat classification scoring engine. Caveats: the whois command always returns empty (the `run()` function blocks it), so "newly registered domain" detection does not work. The Tor exit node check compares against the scanner's own IP, not the target's IP, making it non-functional for target analysis.

### 4.3 Oblivion

VERDICT: UI-ONLY / PLACEHOLDER. The Oblivion route (`src/app/api/oblivion/route.ts`, 211 lines) returns a fully empty report. All 20 tool categories return zero values (bypasses: 0, layers: 0, decaysAchieved: 0). The POST handler builds a massive response structure with all zeros and randomly selects a "wisdom quote." Comments in the code indicate that the Python AI engine was removed ("exec eliminated"). This module has no actual functionality despite an elaborate claims structure describing 20 analytical tools including "Cognitive Mirror," "Theseus Test," and "Alignment Decay Engine."

### 4.4 Model Red Team

VERDICT: MOCK. The Model Red Team (`src/app/api/model-redteam/route.ts`, 955 lines) is partially real in its network probing but mock in its AI security claims. The endpoint discovery function probes 56 AI provider endpoint paths on the target domain via real HTTP requests. CVE matching against 25 AI framework CVEs and secret pattern extraction (12 patterns) use real HTTP responses.

However, the "prompt injection" and "multi-turn chain" tests simply send HTTP requests and check HTTP response status -- they do not interact with any actual LLM. The "fear index," "hall of broken models," and "trauma imprint" are theatrical in-memory scoring systems with no connection to real AI security analysis. The module sends 56+ HTTP requests to arbitrary targets in parallel, which could be logged as reconnaissance by the target.

## 4.5 Hall of Fame

VERDICT: REAL. The Hall of Fame (`src/app/api/hall-of-fame/route.ts`, 236 lines) implements a genuine security grade leaderboard. It performs real HTTP HEAD probes to 5 sensitive paths (`/.env`, `/api/webhooks`, `/admin`, `/dashboard`, `/uploads/`) using `safeFetch` with a 5-second timeout. Scores and letter grades (A+ through F) are computed deterministically from the probe results. Data is persisted in the Prisma `VibeSecEntry` model with proper CRUD operations. The leaderboard supports category filtering and search. The "verified" status is purely score-based (score  $\geq 90$ ) rather than requiring manual verification. No authentication is required to submit domains or manipulate the leaderboard.

## 4.6 Sovereign

VERDICT: MOCK. The Sovereign Control API (`src/app/api/sovereign/route.ts`, 284 lines) uses real Ed25519 cryptographic operations from `sovereign-crypto.ts` for key generation, signing, and verification. However, all "execute" actions (emergency lockdown, key revocation, global broadcast) are simulated -- they return hardcoded responses with `simulated: true`. No actual lockdown, revocation, or broadcast occurs. The in-memory access log (max 100 entries) resets on server restart. Critically, the execute action has NO authentication -- anyone can trigger simulated sovereign actions. The dead man's switch timer is real (30-day heartbeat) but operates only in-memory.

## 4.7 Sandbox (Confused Deputy)

VERDICT: REAL (by design). The Sandbox (`src/app/api/sandbox/route.ts`, 698 lines) implements a pattern-matching chat bot that simulates an AI agent for security training purposes. It is explicitly designed as a simulation -- no real LLM is involved. The system creates sessions with 18 simulated AWS IAM permissions, matches user prompts against approximately 30 regex rules, and scores points for successful prompt injection attacks. A defense mode toggle blocks certain attack categories. The in-memory session store has a 10-minute TTL. This module works exactly as designed -- it is a training tool, not a real sandbox.

## 4.8 Scan / Stream Infrastructure

The scan infrastructure (`POST /api/scan`) is a REAL, comprehensive reconnaissance engine. The streaming endpoint (`GET /api/scan/stream`), however, is UI-ONLY -- it returns fake Server-Sent Events with 21 pre-defined phase events and artificial delays (200-500ms). No actual scan is executed during the stream. The scan lifecycle (create, run, persist findings) is fully implemented with Prisma persistence. Progress tracking is cosmetic. Concurrency is limited by rate limiting (3 requests/minute for scans). Error handling is thorough with `try/catch` around all network operations. Scan cancellation is not implemented -- scans run to completion once started.

## 5. Intelligence Layer Audit

The claimed 8-stage intelligence pipeline (RAW RECON, OBSERVATIONS, FINDINGS, CORRELATION, RISK, BUSINESS IMPACT, REMEDIATION, VERIFICATION) does not exist as a connected, sequential pipeline in the codebase. ReconPro does not have a dedicated intelligence processing engine that takes raw scan output and transforms it through these stages. Instead, the scan engine produces findings directly, and several separate modules provide adjacent functionality that partially covers some pipeline stages. The following is a stage-by-stage audit:

| Pipeline Stage             | Implementation Evidence                                                                   | Status    |
|----------------------------|-------------------------------------------------------------------------------------------|-----------|
| RAW RECON                  | scan/route.ts performs real DNS, TLS, HTTP, port, CT log, Wayback, JS, WAF, email recon   | REAL      |
| OBSERVATIONS               | Finding objects with title/severity/category/evidence/asset/source fields                 | REAL      |
| FINDINGS                   | Finding model in Prisma with CRUD, severity classification, category tagging              | REAL      |
| CORRELATION                | No correlation engine exists. Findings are stored per-scan with no cross-scan correlation | NOT FOUND |
| RISK                       | implosion-engine.ts computes financial risk from scan findings (real math)                | PARTIAL   |
| BUSINESS IMPACT            | implosion-engine.ts: breach cost, fines, reputational damage, stock impact (real)         | REAL      |
| REMEDIATION                | Finding model has remediation field; vuln-scan provides fix guidance in descriptions      | PARTIAL   |
| VERIFICATION               | No remediation verification/retesting workflow exists                                     | NOT FOUND |
| Finding Deduplication      | No deduplication logic across scans                                                       | NOT FOUND |
| Asset Connection           | No asset relationship model (flat ScanTarget model)                                       | NOT FOUND |
| Risk Calculation           | Implosion engine only (executive financial risk, not technical risk scoring)              | PARTIAL   |
| Finding Prioritization     | Severity-based (critical/high/medium/low/info) but no risk-score prioritization           | PARTIAL   |
| Attack Path Identification | Not implemented                                                                           | NOT FOUND |
| Remediation Verification   | Not implemented                                                                           | NOT FOUND |
| Risk Reduction Tracking    | Not implemented                                                                           | NOT FOUND |

# 6. Organization / Team Capabilities

ReconPro has a comprehensive Prisma schema for organization and team management, including Organization, Team, Member, and TeamMember models with proper relational integrity. The CRUD API routes for teams and members are fully implemented with Prisma operations. However, a critical finding is that NONE of these routes have authentication or authorization -- any anonymous user can create, modify, or delete teams and members, including escalating to the "owner" role.

| Capability               | Implementation                                                                      | Status             | Security                   |
|--------------------------|-------------------------------------------------------------------------------------|--------------------|----------------------------|
| Authentication (API Key) | SHA-256 hash lookup in Prisma ApiKey model, scope validation, expiry check          | REAL               | Implemented but opt-in     |
| API Key Management       | ApiKey model with hash, prefix, scopes, rate limiting, expiry, usage tracking       | REAL               | Good                       |
| Authorization (Roles)    | Role constants defined (owner/admin/security_lead/analyst/viewer) but never checked | SCAFFOLD           | No enforcement             |
| Organization CRUD        | Prisma Organization model with full relations                                       | REAL (schema only) | No API route               |
| Team CRUD                | Full GET/POST/PATCH/DELETE via /api/teams with audit logging                        | REAL               | NO AUTH                    |
| Member CRUD              | Full GET/POST/PATCH/DELETE via /api/members with role validation                    | REAL               | NO AUTH                    |
| Rate Limiting            | In-memory Map-based, 50K entry cap, per-IP                                          | REAL               | Resets on restart          |
| Audit Controls           | AuditLog model with action/resource/member tracking                                 | REAL               | Logged but not enforced    |
| Account Isolation        | organizationId foreign key on all models                                            | SCHEMA ONLY        | No query-level enforcement |
| Tenant Isolation         | Multi-tenant schema design                                                          | SCHEMA ONLY        | No middleware enforcement  |
| API Security             | api-protection.ts withProtection() middleware                                       | REAL               | Opt-in per route           |

## 7. Security Engineering Findings

The following security findings were identified through static analysis of the source code. No vulnerabilities were exploited or tested against running infrastructure. All findings are based on code inspection only.

| Severity | Finding                                | Location                        | Mitigation                    | Residual Risk                                 |
|----------|----------------------------------------|---------------------------------|-------------------------------|-----------------------------------------------|
| CRITICAL | No authentication on scan/recon routes | scan/, vuln-scan/, bot-hunter/  | Rate limiting (3/min)         | HIGH - anyone can trigger offensive scans     |
| CRITICAL | No authentication on team/member CRUD  | teams/, members/                | None                          | CRITICAL - anonymous role escalation          |
| CRITICAL | No auth on Sovereign execute actions   | sovereign/route.ts              | Simulated only                | MEDIUM - simulated actions, dangerous pattern |
| HIGH     | SSRF TOCTOU race condition             | safe-fetch.ts                   | DNS pre-check + IP validation | MEDIUM - DNS rebinding possible               |
| HIGH     | Offensive scanning without auth        | scan/, vuln-scan/, bot-hunter/  | Rate limiting                 | HIGH - server IP flagged by targets           |
| HIGH     | WAF detection sends attack payloads    | scan/route.ts detectWAF()       | None                          | MEDIUM - path traversal probes logged         |
| MEDIUM   | In-memory rate limiting only           | api-security.ts                 | 50K entry cap                 | MEDIUM - resets on restart                    |
| MEDIUM   | Duplicated blocked-domain lists        | api-security.ts + safe-fetch.ts | Two separate lists            | LOW - drift risk                              |
| MEDIUM   | Command interpreter complexity         | vuln-scan/, bot-hunter/         | No child_process              | LOW - edge cases possible                     |
| MEDIUM   | AXFR check returns empty               | vuln-scan/route.ts              | handleDig blocks axfr         | LOW - missing capability                      |
| LOW      | IP extraction trusts X-Forwarded-For   | sovereign/route.ts              | Uses first IP (spoofable)     | LOW - duplicated insecure pattern             |
| LOW      | Scan stream is cosmetic                | scan/stream/route.ts            | No real scan runs             | NONE - cosmetic only                          |
| INFO     | No child_process usage anywhere        | Entire codebase                 | N/A                           | NONE - good                                   |
| INFO     | No dangerouslySetInnerHTML             | Entire codebase                 | N/A                           | NONE - good                                   |
| INFO     | No eval() usage                        | Entire codebase                 | N/A                           | NONE - good                                   |

# 8. Testing Evidence

The test suite passes all 562 tests across 22 test files with 0 failures. However, the coverage is heavily skewed toward the api-security utility module and static file analysis. The vast majority of the application's business logic -- 45+ API routes, 8 engine modules, and 70+ React components -- has zero test coverage. Additionally, one test file (api-security.test.ts) re-implements the code under test inline rather than importing from the actual module, providing false confidence.

| Area                         | Files Tested | Files Untested | Coverage Assessment                                                                                                   |
|------------------------------|--------------|----------------|-----------------------------------------------------------------------------------------------------------------------|
| API Routes (46 total)        | 0            | 46             | CRITICAL GAP -- zero HTTP-level tests                                                                                 |
| React Components (70+ total) | 0            | 70+            | CRITICAL GAP -- zero rendering tests                                                                                  |
| Engine Modules (8 total)     | 0            | 8              | HIGH GAP -- broadcast, cni-sentinel, fear-index, genesis-crypto, implosion, pqc-vault, quantum-doom, sovereign-crypto |
| Recon Modules (lib/recon/)   | 5 (mocked)   | 2              | GOOD -- dns-recon, ssl-recon, http-recon, port-check, ssrf-guard tested via mocks                                     |
| Security Utilities           | 5            | 0              | EXCELLENT -- api-security is the most thoroughly tested module                                                        |
| Static Analysis              | 7 files      | N/A            | MEDIUM -- file-reading tests, brittle but useful for basic checks                                                     |
| Mutation Testing             | 1 file       | N/A            | GOOD -- mutation-forge.test.ts with 34 mutation tests                                                                 |
| Chaos/Resilience             | 3 files      | N/A            | GOOD -- chaos-forge, chaos-forge-expanded, resilience-forge                                                           |

## 9. Performance Evidence

Performance measurements were taken during this forensic audit. The build produces a Next.js standalone server with static asset copying. Console logging is stripped in production via the `removeConsole` configuration. Image optimization uses AVIF and WebP formats with a 1-hour cache TTL.

| Metric                | Value               | Notes                                                             |
|-----------------------|---------------------|-------------------------------------------------------------------|
| Build                 | PASS                | next build succeeds with 0 errors                                 |
| Console Removal       | Active              | <code>removeConsole: process.env.NODE_ENV === "production"</code> |
| Image Formats         | AVIF, WebP          | Configured in <code>next.config.ts</code>                         |
| Cache TTL             | 3600s (1 hour)      | <code>minimumCacheTTL</code> setting                              |
| Test Suite Duration   | 20.27s              | 562 tests total                                                   |
| Rate Limiter          | In-memory Map, O(1) | 50K entry cap with amortized cleanup                              |
| CT Log Response Cap   | 5MB                 | <code>MAX_CT_RESPONSE_SIZE</code> in <code>ct-logs.ts</code>      |
| Subdomain Cap         | 5,000               | <code>MAX_SUBDOMAINS</code> in <code>ct-logs.ts</code>            |
| HTTP Response Cap     | 2MB                 | <code>safeFetch</code> streaming limit                            |
| Body Size Limit       | 1MB                 | <code>parseValidatedBody</code> default                           |
| Port Scan Timeout     | 2s per port         | 27 ports in parallel                                              |
| DNS Resolver Timeout  | 5s per record type  | 7 record types in parallel                                        |
| Concurrent Port Scans | 27 simultaneous     | <code>Promise.allSettled</code> pattern                           |

## 10. Database / Persistence Evidence

ReconPro uses Prisma ORM with SQLite as the database provider. The schema defines 17 models covering organizations, teams, members, scans, findings, compliance, monitoring, integrations, API keys, audit logs, and specialized modules (`VibeSecEntry`, `NHIIIdentity`, `NHIREvocation`, `NHIAuditLog`, `NHIImpactAssessment`, `GenesisStamp`, `GenesisAuditTrail`, `ImplosionScenario`). All models use `cuid()` for primary keys. Relational integrity is enforced through foreign key constraints. However, there is no query-level tenant isolation -- while the schema has `organizationId` on most models, the API routes do not consistently filter by organization, and there is no Prisma middleware enforcing multi-tenancy.

| Model        | Purpose                                | Used By                                          | Tenant Isolation          |
|--------------|----------------------------------------|--------------------------------------------------|---------------------------|
| Organization | Top-level entity with plan/quota/SSO   | teams, members, scan targets                     | Schema only               |
| Team         | Team grouping within org               | <code>/api/teams</code>                          | Schema only               |
| Member       | User accounts with roles               | <code>/api/members</code>                        | Schema only               |
| TeamMember   | Many-to-many team membership           | teams, members                                   | Schema only               |
| ScanTarget   | Domain/IP targets with tags/importance | <code>/api/scan</code> , <code>/api/scans</code> | No org scoping in queries |

| Model             | Purpose                                             | Used By                         | Tenant Isolation      |
|-------------------|-----------------------------------------------------|---------------------------------|-----------------------|
| Scan              | Scan execution records with severity counts         | /api/scan, /api/scans           | No org scoping        |
| Finding           | Individual findings with severity/category/evidence | /api/scan                       | Per-scan only         |
| ThreatAlert       | Threat intelligence alerts                          | /api/threats                    | No tenant isolation   |
| ComplianceReport  | Framework compliance scores                         | /api/compliance                 | Org-scoped            |
| MonitorPolicy     | Scheduled scan policies                             | /api/monitoring                 | Org-scoped            |
| Integration       | External integrations (Slack, Jira, etc.)           | /api/integrations               | Org-scoped            |
| ApiKey            | SHA-256 hashed API keys with scopes                 | api-protection.ts, /api/v1/auth | Org-scoped            |
| AuditLog          | Action audit trail                                  | teams, members, genesis         | Partial org scoping   |
| VibeSecEntry      | Hall of Fame security grades                        | /api/hall-of-fame               | None                  |
| NHIIdentity       | Non-human identity tracking                         | /api/nhi/*                      | Hardcoded org_default |
| GenesisStamp      | Cryptographic attestation stamps                    | /api/genesis/*                  | Optional org link     |
| ImplosionScenario | Risk simulation results                             | /api/implosion                  | Optional org link     |

# 11. UI to Backend Trace

This section traces the major ReconPro UI features to their actual backend implementations. A feature is classified as "Fully Connected" when the UI component calls a real API route that performs real work and persists results. "Partially Connected" means the UI calls a real API but the backend is incomplete. "Mocked" means the backend returns hardcoded or synthetic data. "Static" means the UI component renders static content with no API calls.

| UI Component                      | API Route                 | Backend Reality                           | Connection                  |
|-----------------------------------|---------------------------|-------------------------------------------|-----------------------------|
| scan-input.tsx + scan-results.tsx | /api/scan (POST)          | Real recon engine with Prisma persistence | FULLY CONNECTED             |
| scan-overlay.tsx                  | /api/scan/stream (GET)    | Fake SSE with hardcoded phases            | MOCKED                      |
| hall-of-fame.tsx                  | /api/hall-of-fame         | Real HTTP probes + DB persistence         | FULLY CONNECTED             |
| vuln-arsenal.tsx                  | /api/vuln-scan            | Real vuln scanning with banner grab       | FULLY CONNECTED             |
| bot-cage.tsx                      | /api/bot-hunter           | Real IP reputation + C2 port scan         | FULLY CONNECTED             |
| oblivion.tsx                      | /api/oblivion             | All zeros, empty report                   | MOCKED                      |
| model-breaker.tsx                 | /api/model-redteam        | Partial real probing, mock AI testing     | PARTIALLY CONNECTED         |
| sovereign-control.tsx             | /api/sovereign            | Real crypto, simulated actions            | PARTIALLY CONNECTED         |
| nhi-kill-switch.tsx               | /api/nhi/*                | Real CRUD + hardcoded sample data         | PARTIALLY CONNECTED         |
| team-management.tsx               | /api/teams + /api/members | Real CRUD, no auth                        | FULLY CONNECTED (unsecured) |
| fear-index.tsx                    | /api/fear-index/*         | Real math on synthetic data               | PARTIALLY CONNECTED         |
| doom-clock.tsx                    | /api/doom-clock           | Real computation on projection data       | PARTIALLY CONNECTED         |
| implosion-panel.tsx               | /api/implosion            | Real financial simulation                 | FULLY CONNECTED             |
| genesis-stamp.tsx                 | /api/genesis/*            | Real Ed25519 signing + verification       | FULLY CONNECTED             |
| cni-sentinel.tsx                  | /api/cni-sentinel         | Expert system scoring on user input       | PARTIALLY CONNECTED         |
| pqc-vault.tsx                     | /api/pqc-vault            | Real PQC readiness scoring                | PARTIALLY CONNECTED         |
| attack-surface.tsx                | /api/scan + /api/scans    | Real scan data, no graph engine           | PARTIALLY CONNECTED         |
| bento-dashboard.tsx               | /api/dashboard            | Aggregate DB queries                      | FULLY CONNECTED             |
| broadcast-center.tsx              | /api/broadcast/*          | Real signing + in-memory store            | PARTIALLY CONNECTED         |
| wall-of-shame.tsx                 | /api/wall-of-shame        | DB query                                  | FULLY CONNECTED             |
| pricing-plans.tsx                 | None                      | Static pricing content                    | STATIC                      |
| HeroSection.tsx                   | None                      | Static hero content                       | STATIC                      |
| ModulesSection.tsx                | None                      | Static module descriptions                | STATIC                      |
| EnterpriseSection.tsx             | None                      | Static enterprise content                 | STATIC                      |

| UI Component | API Route | Backend Reality | Connection |
|--------------|-----------|-----------------|------------|
| Footer.tsx   | None      | Static footer   | STATIC     |

## 12. Master Capability Matrix

This matrix covers every verified capability across all domains. Each capability was traced to its implementation file(s), tested where tests exist, and verified against actual code behavior rather than claims or UI presence.

| Domain              | Capability                    | Impl% | Tests | DB  | Status      |
|---------------------|-------------------------------|-------|-------|-----|-------------|
| Recon               | DNS Record Enumeration        | 95%   | Yes   | No  | REAL        |
| Recon               | TLS/SSL Certificate Analysis  | 90%   | Yes   | No  | REAL        |
| Recon               | HTTP Security Header Analysis | 90%   | Yes   | No  | REAL        |
| Recon               | Port Probing (TCP)            | 90%   | Yes   | No  | REAL        |
| Recon               | CT Log Subdomain Discovery    | 85%   | No    | No  | REAL        |
| Recon               | Subdomain DNS Resolution      | 80%   | No    | No  | REAL        |
| Recon               | Technology Fingerprinting     | 85%   | No    | No  | REAL        |
| Recon               | WAF Detection                 | 70%   | No    | No  | REAL        |
| Recon               | JS File Analysis              | 70%   | No    | No  | REAL        |
| Recon               | Wayback Machine History       | 70%   | No    | No  | REAL        |
| Recon               | Email Harvesting              | 65%   | No    | No  | REAL        |
| Recon               | WHOIS Lookup                  | 0%    | No    | No  | NOT WORKING |
| Recon               | Reverse DNS                   | 80%   | No    | No  | REAL        |
| Attack Surface      | Subdomain Discovery           | 85%   | No    | No  | REAL        |
| Attack Surface      | Port/Service Discovery        | 90%   | No    | No  | REAL        |
| Attack Surface      | Asset Relationships           | 0%    | No    | No  | NOT FOUND   |
| Security Assessment | Vulnerability Scanning        | 85%   | No    | No  | REAL        |
| Security Assessment | Security Header Checks        | 90%   | Yes   | No  | REAL        |
| Security Assessment | Finding Generation            | 90%   | No    | Yes | REAL        |
| Security Assessment | Severity Classification       | 90%   | No    | Yes | REAL        |
| Security Assessment | Evidence Collection           | 80%   | No    | Yes | REAL        |
| Security Assessment | Report Generation             | 60%   | No    | Yes | PARTIAL     |
| Security Assessment | Remediation Info              | 50%   | No    | Yes | PARTIAL     |
| Security Assessment | Verification/Retesting        | 0%    | No    | No  | NOT FOUND   |
| Engines             | Vulnerability Scanner         | 85%   | No    | No  | REAL        |

| Domain         | Capability                | Impl% | Tests | DB  | Status                    |
|----------------|---------------------------|-------|-------|-----|---------------------------|
| Engines        | Bot Hunter                | 75%   | No    | No  | REAL (caveats)            |
| Engines        | Oblivion                  | 5%    | No    | No  | UI-ONLY                   |
| Engines        | Model Red Team            | 25%   | No    | No  | MOCK                      |
| Engines        | Hall of Fame              | 80%   | No    | Yes | REAL                      |
| Engines        | Sovereign                 | 30%   | No    | No  | MOCK                      |
| Engines        | Sandbox                   | 85%   | No    | No  | REAL (simulation)         |
| Engines        | Scan/Stream               | 50%   | No    | No  | PARTIAL (stream is fake)  |
| Intelligence   | Financial Risk Simulation | 90%   | No    | Yes | REAL                      |
| Intelligence   | Fear Index                | 70%   | No    | No  | PARTIAL (synthetic data)  |
| Intelligence   | Quantum Doom Clock        | 70%   | No    | No  | PARTIAL (projection data) |
| Intelligence   | PQC Readiness             | 70%   | No    | No  | PARTIAL (table lookup)    |
| Intelligence   | CNI Threat Analysis       | 70%   | No    | No  | PARTIAL (expert system)   |
| Intelligence   | Correlation Engine        | 0%    | No    | No  | NOT FOUND                 |
| Intelligence   | Risk Prioritization       | 30%   | No    | No  | PARTIAL                   |
| Teams          | Organization Model        | 100%  | No    | Yes | REAL (schema only)        |
| Teams          | Team CRUD                 | 70%   | No    | Yes | REAL (no auth)            |
| Teams          | Member CRUD               | 70%   | No    | Yes | REAL (no auth)            |
| Auth           | API Key Authentication    | 90%   | No    | Yes | REAL (opt-in)             |
| Auth           | API Key Validation        | 90%   | No    | Yes | REAL                      |
| Auth           | Role-Based Access         | 10%   | No    | No  | SCAFFOLD                  |
| Auth           | Rate Limiting             | 85%   | Yes   | No  | REAL                      |
| Security       | SSRF Protection           | 90%   | Yes   | No  | REAL                      |
| Security       | CSP with Nonce            | 95%   | Yes   | No  | REAL                      |
| Security       | HSTS                      | 95%   | Yes   | No  | REAL                      |
| Security       | X-Frame-Options DENY      | 95%   | Yes   | No  | REAL                      |
| Security       | Blocked Domain List       | 95%   | Yes   | No  | REAL                      |
| Infrastructure | Scan Persistence          | 90%   | No    | Yes | REAL                      |
| Infrastructure | Finding Persistence       | 90%   | No    | Yes | REAL                      |
| Infrastructure | Audit Logging             | 80%   | No    | Yes | REAL                      |
| Infrastructure | Genesis Attestation       | 90%   | No    | Yes | REAL (Ed25519)            |
| Infrastructure | Broadcast Signing         | 85%   | No    | No  | REAL (Ed25519)            |
| Infrastructure | Sovereign Crypto          | 85%   | No    | No  | REAL (Ed25519)            |

# 13. Implemented vs. Partial vs. Future

## 13.1 INVENTORY A -- REAL TODAY

Capabilities with direct, verified repository evidence of working implementation. These capabilities perform real network operations, generate real findings, persist to the database, and have proper input validation and SSRF protection. Each was traced through the source code to confirm meaningful working logic.

| Category | Capability                                                                        |
|----------|-----------------------------------------------------------------------------------|
| Recon    | DNS record enumeration (7 types: A, AAAA, MX, NS, TXT, CNAME, SOA)                |
| Recon    | TLS/SSL certificate analysis (handshake, cert metadata, expiry, protocol, cipher) |
| Recon    | HTTP security header analysis (8 headers: HSTS, CSP, X-Frame-Options, etc.)       |
| Recon    | Technology detection (35+ fingerprints: CDN, server, framework, CMS, analytics)   |
| Recon    | TCP port probing (27 unique ports with risk classification)                       |
| Recon    | CT log subdomain discovery (crt.sh with 5K cap)                                   |
| Recon    | SPF/DMARC email security analysis                                                 |
| Recon    | Wayback Machine URL history discovery                                             |
| Recon    | JS file analysis (API endpoints, secrets, internal paths)                         |
| Recon    | WAF detection (path traversal probe + rate limit test)                            |
| Recon    | Email harvesting + MX infrastructure analysis                                     |
| Security | Vulnerability scanning (banner grab, HTTP vulns, SSL vulns, DNS vulns)            |
| Security | Bot hunting (IP reputation, C2 ports, malware sigs, DNS analysis, typosquatting)  |
| Security | Hall of Fame security grading (HTTP probes + leaderboard)                         |
| Security | Finding generation with severity classification                                   |
| Security | SSRF protection (blocked domains, private IP, DNS resolution check)               |
| Engines  | Implosion engine (real financial risk simulation)                                 |
| Engines  | Sandbox (pattern-matching AI agent simulation)                                    |
| Crypto   | Genesis attestation (Ed25519 signing + SHA-256)                                   |
| Crypto   | Broadcast signing (Ed25519 sign + verify)                                         |
| Crypto   | Sovereign crypto (Ed25519 key management)                                         |
| Infra    | Scan persistence (ScanTarget + Scan + Finding models)                             |
| Infra    | API key authentication (SHA-256 hash + scope + expiry)                            |
| Infra    | Audit logging (AuditLog model with action/resource tracking)                      |
| Infra    | Team/Member CRUD (Prisma operations with role validation)                         |
| Infra    | Compliance framework scoring                                                      |
| Infra    | Security middleware (CSP, HSTS, X-Frame-Options, COOP, CORP, COEP)                |

## 13.2 INVENTORY B -- PARTIAL

Capabilities where infrastructure exists but the complete workflow is incomplete. These have real computation or real partial implementation, but operate on synthetic data, lack critical features, or are not fully connected.

| Category     | Capability                | Gap                                                             |
|--------------|---------------------------|-----------------------------------------------------------------|
| Intelligence | Fear Index                | Real math on PRNG-generated synthetic threat data               |
| Intelligence | Quantum Doom Clock        | Real computation on speculative projection data                 |
| Intelligence | PQC Readiness Assessment  | Real scoring engine, no actual PQC crypto operations            |
| Intelligence | CNI Sentinel              | Expert system with real domain data, no live scanning           |
| Engines      | Model Red Team            | Real HTTP probing, mock AI testing claims                       |
| Engines      | Sovereign                 | Real crypto, simulated side effects                             |
| Engines      | Scan Stream               | Real SSE protocol, fake scan data                               |
| Engines      | NHI Kill Switch           | Real CRUD, hardcoded sample data insertion                      |
| Teams        | Role-Based Access Control | Roles defined, never enforced                                   |
| Teams        | Tenant Isolation          | Schema design exists, no query-level enforcement                |
| Recon        | WHOIS Lookup              | Infrastructure exists (run() interpreter), always returns empty |
| Security     | Remediation Verification  | Finding remediation field exists, no retesting workflow         |
| Security     | Risk Prioritization       | Severity-based sorting, no risk-score calculation               |

## 13.3 INVENTORY C -- NOT IMPLEMENTED

Capabilities that are claimed, planned, or architecturally described but have no implementation in the codebase. These may exist as UI components, comments, README entries, or architectural diagrams, but no working code.

| Category       | Capability                               | Evidence of Claim                                  |
|----------------|------------------------------------------|----------------------------------------------------|
| Intelligence   | Finding correlation/deduplication engine | No cross-scan analysis code exists                 |
| Intelligence   | Asset relationship mapping               | No relationship model in Prisma schema             |
| Intelligence   | Attack path identification               | No graph engine or path analysis                   |
| Intelligence   | Remediation verification/retesting       | No retesting workflow                              |
| Intelligence   | Risk reduction tracking                  | No temporal risk tracking                          |
| Security       | Authentication enforcement on API routes | Auth middleware exists but is opt-in, not used     |
| Security       | Authorization/permission checks          | Role constants defined, never checked              |
| Engines        | Oblivion (AI model red teaming)          | Route exists, returns all zeros                    |
| Infrastructure | Multi-tenant query enforcement           | Schema has orgId, no Prisma middleware             |
| Infrastructure | Persistent rate limiting                 | In-memory only, resets on restart                  |
| Infrastructure | Scan cancellation                        | No cancellation mechanism                          |
| Infrastructure | Real external broadcast delivery         | In-memory store only, no Slack/Jira/email delivery |

# 14. Evidence-Derived Product Capability Score

Each domain is scored 0-10 based ONLY on verified repository evidence. Scores are not inflated. If the real score is 6.2, it is reported as 6.2. Scoring criteria: 10 = production-grade with tests, auth, persistence, and error handling. 8-9 = fully implemented with minor gaps. 6-7 = real implementation with significant gaps. 4-5 = partial implementation or mock with real components. 2-3 = scaffold/placeholder. 0-1 = not found.

| Domain                   | Score | Evidence Summary                                                                                              |
|--------------------------|-------|---------------------------------------------------------------------------------------------------------------|
| Reconnaissance           | 8.5   | Real DNS/TLS/HTTP/port/CT recon with SSRF protection. Missing WHOIS. Well-tested security layer.              |
| Attack-Surface Discovery | 7.0   | Real subdomain/port/service discovery. No asset relationships or graph engine.                                |
| Security Assessment      | 7.5   | Real vuln scanning, header analysis, finding generation. No correlation or verification workflow.             |
| Specialized Intelligence | 5.0   | 3 real engines (Hall of Fame, Bot Hunter, Sandbox). 2 mock (Oblivion, Sovereign). 1 partial (Model Red Team). |
| Correlation & Analysis   | 1.5   | No correlation, deduplication, or asset relationship engine. Implosion engine provides financial risk only.   |
| Risk Analysis            | 4.0   | Financial risk simulation is real and thorough. Technical risk scoring and prioritization are absent.         |
| Remediation              | 3.0   | Finding descriptions include fix guidance. No remediation workflow, verification, or tracking.                |
| Authentication           | 4.0   | API key system is well-implemented but opt-in. Most routes have zero auth.                                    |
| Authorization            | 1.0   | Roles defined in schema but never enforced in any API route.                                                  |
| Team Functionality       | 5.0   | Full CRUD with audit logging. No authentication. Role escalation possible.                                    |
| Reporting                | 4.0   | Finding model has remediation field. No report generation engine. HTML reports only.                          |
| Testing Quality          | 4.5   | 562/562 pass. Heavy bias toward api-security utility. Zero API route/component/engine tests.                  |
| Security Engineering     | 7.5   | Excellent SSRF protection, CSP with nonce, HSTS, no unsafe code. Critical auth gaps.                          |
| Reliability              | 7.0   | Build passes, 0 TS errors, thorough error handling. In-memory rate limiting is fragile.                       |
| Performance              | 7.5   | Good resource caps (5MB CT, 2MB HTTP, 1K subdomain). Concurrent port scanning. Console stripped in prod.      |
| Observability            | 4.0   | Audit logging exists. No metrics, no tracing, no health dashboard backend.                                    |
| UX (Component Count)     | 9.0   | 70+ ReconPro components, 40+ shadcn/ui, polished OLED dark design, animations.                                |
| Architecture             | 6.5   | Clean separation: lib/recon engines, lib/security, API routes, Prisma models. Some duplication.               |
| Production Readiness     | 4.0   | Build passes, security headers good. No auth on critical routes. No multi-tenant enforcement. No E2E tests.   |

**OVERALL WEIGHTED SCORE: 5.2 / 10**



# 15. Claim Verification

| Claim                                                   | Verdict  | Evidence                                                                                        |
|---------------------------------------------------------|----------|-------------------------------------------------------------------------------------------------|
| ReconPro is a complete reconnaissance platform          | PARTIAL  | Excellent recon, but intelligence pipeline, auth, and remediation are incomplete                |
| ReconPro performs domain reconnaissance                 | VERIFIED | Real DNS, TLS, HTTP, port, CT, Wayback, JS, WAF, email analysis                                 |
| ReconPro performs DNS intelligence                      | VERIFIED | 7 record types, SPF/DMARC/SECURITY.TXT analysis, 3 custom resolvers                             |
| ReconPro performs IP/host discovery                     | VERIFIED | A/AAAA resolution, reverse DNS, private IP blocking, geolocation                                |
| ReconPro performs subdomain reconnaissance              | VERIFIED | CT logs (crt.sh) + 60-90 pattern batched DNS resolution                                         |
| ReconPro performs WHOIS intelligence                    | FALSE    | Infrastructure exists but always returns empty string                                           |
| ReconPro performs TLS/SSL inspection                    | VERIFIED | Real TLS handshake, cert metadata, expiry, cipher, SAN, protocol analysis                       |
| ReconPro performs certificate transparency intelligence | VERIFIED | Real crt.sh API queries with streaming and 5K cap                                               |
| ReconPro performs HTTP/HTTPS reconnaissance             | VERIFIED | 8 security headers, 35+ technology fingerprints, page title extraction                          |
| ReconPro identifies technologies/services               | VERIFIED | 35+ fingerprints across CDN, server, framework, CMS, analytics, WAF categories                  |
| ReconPro performs network/service probing               | VERIFIED | TCP port scanning of 27 critical ports with risk classification                                 |
| ReconPro performs security-header analysis              | VERIFIED | 8 headers: HSTS, CSP, X-Frame-Options, X-Content-Type-Options, etc.                             |
| ReconPro performs attack-surface mapping                | PARTIAL  | Real subdomain/port discovery but no asset relationship graph or visualization backend          |
| ReconPro performs vulnerability discovery               | VERIFIED | Banner grab, HTTP vulns (CORS, XSS, SSRF, etc.), SSL vulns, DNS vulns                           |
| ReconPro performs web/API security checks               | VERIFIED | CORS, open redirect, path traversal, XSS, clickjacking, cookies, CSRF, mixed content            |
| ReconPro provides SSRF-aware reconnaissance             | VERIFIED | Comprehensive SSRF guard: blocked domains, private IPs (v4+v6), DNS resolution check, safeFetch |
| ReconPro performs security configuration analysis       | VERIFIED | DNS (SPF/DMARC), TLS (protocol/cipher/expiry), HTTP (8 security headers)                        |
| ReconPro detects exposure                               | PARTIAL  | Real HTTP path probing but no comprehensive exposure detection engine                           |
| ReconPro classifies findings                            | VERIFIED | Severity (critical/high/medium/low/info) + category (dns/subdomain/port/ssl/header/etc.)        |
| ReconPro assesses severity                              | VERIFIED | 5-level severity model with evidence-based assessment in all recon modules                      |
| ReconPro collects evidence                              | VERIFIED | Raw DNS records, cert data, HTTP headers, port banners, response bodies captured                |
| ReconPro generates reports                              | PARTIAL  | HTML scan reports generated. No PDF/Word report engine. No compliance report generation.        |

| Claim                                          | Verdict  | Evidence                                                                                                      |
|------------------------------------------------|----------|---------------------------------------------------------------------------------------------------------------|
| ReconPro has Vulnerability Scanner             | VERIFIED | Real banner grab + 35+ CVE matching + HTTP/SSL/DNS vuln checks                                                |
| ReconPro has Bot Hunter                        | VERIFIED | Real IP reputation, 30 C2 ports, 18 malware families, DNS analysis, typosquatting                             |
| ReconPro has Oblivion                          | FALSE    | Route exists but returns all zeros. Python engine removed. No functionality.                                  |
| ReconPro has Model Red Team                    | FALSE    | Real HTTP probing exists, but AI testing claims are theatrical. No real LLM interaction.                      |
| ReconPro has Hall of Fame                      | VERIFIED | Real HTTP probe-based security grading with leaderboard and DB persistence                                    |
| ReconPro has Sovereign                         | FALSE    | Real crypto exists but all actions are simulated. No real lockdown/revocation.                                |
| ReconPro has Sandbox                           | VERIFIED | Real pattern-matching simulation by design -- training tool for prompt injection defense                      |
| ReconPro has Scan/Stream infrastructure        | PARTIAL  | Real scan execution. Stream endpoint is fake SSE with hardcoded phases.                                       |
| ReconPro has teams                             | PARTIAL  | Real CRUD with Prisma. No authentication. Anonymous role escalation possible.                                 |
| ReconPro has organizations                     | PARTIAL  | Full Prisma schema. No API route for org CRUD. No query-level enforcement.                                    |
| ReconPro has API authentication                | PARTIAL  | Well-implemented SHA-256 API key system but opt-in -- most routes unprotected                                 |
| ReconPro has API keys                          | VERIFIED | Full lifecycle: creation, hashing, prefix, scopes, expiry, usage tracking, validation                         |
| ReconPro has rate limiting                     | VERIFIED | In-memory Map-based per-IP rate limiting with 50K entry cap                                                   |
| ReconPro has security middleware               | VERIFIED | CSP with nonce, HSTS preload, X-Frame-Options DENY, COOP, CORP, COEP, no X-Powered-By                         |
| ReconPro has centralized security architecture | PARTIAL  | api-security.ts + safe-fetch.ts + ssrf-guard.ts + api-protection.ts are centralized but duplicated and opt-in |

# 16. No-Code Integrity Verification

This audit was conducted in strict compliance with the absolute no-code rule. The following integrity verification confirms that no source code, tests, configuration, or dependencies were modified during the forensic examination:

| Item                   | Status | Verification                                                           |
|------------------------|--------|------------------------------------------------------------------------|
| Source files modified  | 0      | No Write/Edit tool was called on any source file                       |
| Test files modified    | 0      | No test was added, removed, or modified                                |
| Configuration modified | 0      | No config file was changed (next.config.ts, tsconfig.json, etc.)       |
| Dependencies modified  | 0      | No package was installed, removed, or updated                          |
| Implementation changes | 0      | No new features, bug fixes, or refactoring performed                   |
| Scripts created        | 1      | This report generation script only (not part of the repository)        |
| Files read             | 200+   | All inspection was read-only via Read/Grep/LBash tools                 |
| Commands executed      | 5      | Only read-only commands: find, wc, ls, tsc, eslint, vitest, next build |
| Database modifications | 0      | No Prisma operations performed beyond schema reading                   |

# 17. Production Readiness Assessment

ReconPro demonstrates strong technical foundations in its reconnaissance engine, security infrastructure, and frontend design. The build is clean (0 TypeScript errors, 0 lint errors, 0 child\_process usage), the security middleware is comprehensive (CSP, HSTS, X-Frame-Options, COOP/CORP/COEP), and the SSRF protection is well-engineered with multi-layer validation. The 562-test suite provides good coverage for the security utility layer.

However, the platform has significant production readiness gaps. The most critical is the absence of authentication on all offensive scanning routes -- any anonymous user can trigger vulnerability scans, port probes, and bot-hunting against arbitrary targets. The team and member CRUD routes are similarly unprotected, allowing anonymous role escalation to "owner." The intelligence pipeline is incomplete, with no finding correlation, asset relationships, or remediation verification. The Oblivion and Model Red Team modules are effectively non-functional, returning empty or theatrical data. Test coverage is heavily skewed toward the security utility layer, with zero tests for API routes, React components, or engine modules. The in-memory rate limiter resets on server restart, providing no protection across deployments.

## 17.1 Launch Blockers

| Blocker                                                                      | Severity | Impact                                                                  |
|------------------------------------------------------------------------------|----------|-------------------------------------------------------------------------|
| No authentication on offensive scanning routes (scan, vuln-scan, bot-hunter) | CRITICAL | Anyone can trigger attacks against arbitrary targets from the server IP |
| No authentication on team/member CRUD with role escalation                   | CRITICAL | Anonymous users can create admin accounts and escalate to owner         |
| No multi-tenant enforcement (schema exists, queries unprotected)             | HIGH     | Any user can potentially access another organization's data             |

| Blocker                                           | Severity | Impact                                            |
|---------------------------------------------------|----------|---------------------------------------------------|
| Oblivion module is non-functional (returns zeros) | MEDIUM   | Claimed capability does not exist                 |
| Model Red Team is mock (theatrical scoring)       | MEDIUM   | Claimed AI security testing is fake               |
| WHOIS lookup is broken (always returns empty)     | LOW      | Claimed recon capability is non-functional        |
| Zero API route tests                              | HIGH     | No regression protection for 46 route handlers    |
| Zero component tests                              | HIGH     | No regression protection for 70+ React components |
| In-memory rate limiting only                      | MEDIUM   | Resets on restart, no cross-instance protection   |
| No scan cancellation mechanism                    | LOW      | Long-running scans cannot be stopped              |
| Sovereign execute has no auth                     | MEDIUM   | Dangerous pattern even if actions are simulated   |

# 18. Recommended Next Engineering Mission

---

Based on the forensic findings, the following engineering mission is recommended in priority order. This mission addresses the most critical gaps identified during the audit and would bring ReconPro from a powerful recon tool to a production-grade enterprise security platform.

## Phase 1: Authentication & Authorization Hardening (CRITICAL)

- Implement `withProtection({ requireAuth: true })` on ALL scan/recon/offensive routes
- Implement authentication on team/member CRUD routes
- Implement Prisma middleware for tenant isolation (filter all queries by `organizationId`)
- Add role-based access control enforcement to all protected routes
- Move rate limiting to Redis or database-backed store

## Phase 2: Test Coverage Expansion (HIGH)

- Add API route tests for all 46 routes (request/response cycle tests)
- Fix `api-security.test.ts` to import from actual module instead of re-implementing
- Add component rendering tests for critical UI components
- Add engine module tests for all 8 untested engines

## Phase 3: Intelligence Pipeline Completion (HIGH)

- Build finding correlation and deduplication engine
- Add asset relationship model to Prisma schema
- Implement remediation verification workflow
- Add risk scoring and prioritization engine

## Phase 4: Dead Code Removal & Mock Replacement (MEDIUM)

- Remove or properly implement Oblivion module
- Fix Model Red Team to perform real AI security analysis or remove AI claims
- Fix WHOIS lookup (currently always returns empty)
- Fix Bot Hunter Tor check (currently checks scanner IP, not target IP)

## Phase 5: Infrastructure Hardening (MEDIUM)

- Implement persistent rate limiting (Redis or database-backed)

- Add scan cancellation mechanism
- Implement real external broadcast delivery (Slack, Jira, email)
- Add real report generation (PDF/Word)
- Add E2E tests

# 19. Evidence Locations

| Evidence Type        | Location(s)                                    |
|----------------------|------------------------------------------------|
| DNS Recon Engine     | src/lib/recon/dns-recon.ts (342 lines)         |
| SSL Recon Engine     | src/lib/recon/ssl-recon.ts (386 lines)         |
| HTTP Recon Engine    | src/lib/recon/http-recon.ts (337 lines)        |
| Port Check Engine    | src/lib/recon/port-check.ts (245 lines)        |
| CT Log Engine        | src/lib/recon/ct-logs.ts (217 lines)           |
| SSRF Guard           | src/lib/recon/ssrf-guard.ts (81 lines)         |
| Recon Types          | src/lib/recon/types.ts (106 lines)             |
| Findings Formatter   | src/lib/recon/findings-formatter.ts (52 lines) |
| API Security         | src/lib/api-security.ts (340 lines)            |
| Safe Fetch           | src/lib/safe-fetch.ts (215 lines)              |
| API Protection       | src/lib/api-protection.ts (250 lines)          |
| Genesis Crypto       | src/lib/genesis-crypto.ts (111 lines)          |
| Sovereign Crypto     | src/lib/sovereign-crypto.ts (430 lines)        |
| Broadcast Engine     | src/lib/broadcast-engine.ts (435 lines)        |
| Implosion Engine     | src/lib/implosion-engine.ts (750 lines)        |
| Fear Index Engine    | src/lib/fear-index-engine.ts (539 lines)       |
| PQC Vault Engine     | src/lib/pqc-vault-engine.ts (773 lines)        |
| CNI Sentinel Engine  | src/lib/cni-sentinel-engine.ts (1,117 lines)   |
| Quantum Doom Engine  | src/lib/quantum-doom-engine.ts (1,184 lines)   |
| Native DNS           | src/lib/native-dns.ts (216 lines)              |
| DB Client            | src/lib/db.ts (12 lines)                       |
| Scan Route           | src/app/api/scan/route.ts (1,245 lines)        |
| Vuln Scan Route      | src/app/api/vuln-scan/route.ts (903 lines)     |
| Bot Hunter Route     | src/app/api/bot-hunter/route.ts (598 lines)    |
| Oblivion Route       | src/app/api/oblivion/route.ts (211 lines)      |
| Model Red Team Route | src/app/api/model-redteam/route.ts (955 lines) |
| Hall of Fame Route   | src/app/api/hall-of-fame/route.ts (236 lines)  |
| Sovereign Route      | src/app/api/sovereign/route.ts (284 lines)     |
| Sandbox Route        | src/app/api/sandbox/route.ts (698 lines)       |
| Scan Stream Route    | src/app/api/scan/stream/route.ts (76 lines)    |
| Middleware           | src/middleware.ts (65 lines)                   |
| Prisma Schema        | prisma/schema.prisma (370 lines)               |
| Package Config       | package.json (83 lines)                        |
| Next.js Config       | next.config.ts (15 lines)                      |

| Evidence Type | Location(s)                            |
|---------------|----------------------------------------|
| Test Files    | src/___tests___/ (22 files, 562 tests) |